



Universidad Politécnica de San Luis Potosí

Laboratorio 02- Traversal sequences blocked with absolute path bypass

.

Asignatura: CNO IV Seguridad Informática

Presenta:

Andrea Morúa Bravo 185548

Docente:

Mtro. Servando López Contreras

Contenido

1.	Información del laboratorio.....	3
2.	Marco teórico y fundamentación técnica.....	3
2.1	Definición y mecanismo	3
2.2	Variantes de la vulnerabilidad	3
2.3	Diferencias entre bases de datos.....	4
2.4	Impacto en la tríada CIA y OWASP.....	4
3.	Procedimiento	4
	Paso 1: Intercepción inicial	4
	Paso 2: Reenvío de petición con forward	5
	Paso 3: Identificación del endpoint vulnerable.....	5
	Paso 4: Módulo repeater	5
	Paso 5: Evaluación del control de seguridad	5
	Paso 6: Inyección del payload	6
	Paso 7: Verificación de respuesta.....	7
	Paso 8: Confirmación de resolución	8
4.	Explicación del Payload	9
5.	Mitigaciones	9
6.	Referencias bibliográficas	10

1. Información del laboratorio

- **Nombre del laboratorio:** Traversal sequences blocked with absolute path bypass.
- **Nivel de dificultad:** Practitioner
- **Tipo de explotación:** File path traversal
- **Objetivo:** Recuperar y desplegar el contenido del archivo de configuración del sistema `/etc/passwd`.
- **Explicación técnica de la vulnerabilidad:** La aplicación web intenta proteger la carga de imágenes bloqueando o filtrando las secuencias de navegación relativa (como `../`). Sin embargo, el backend procesa el valor del parámetro `filename` pasándolo directamente a las funciones de lectura del sistema de archivos sin validar si la entrada es una ruta absoluta. Al ingresar directamente `/etc/passwd`, el servidor omite la búsqueda en el directorio de recursos y lee el archivo desde la raíz del sistema.

2. Marco teórico y fundamentación técnica

2.1 Definición y mecanismo

En muchas aplicaciones web, los desarrolladores intentan solucionar las vulnerabilidades de File Path Traversal aplicando filtros superficiales o listas negras que buscan y eliminan las secuencias de escape relativas `../` o `..\` (PortSwigger, s.f.).

Cuando el backend recibe la entrada del usuario y utiliza funciones nativas del sistema operativo se interpretan tanto rutas relativas como rutas absolutas. Si la aplicación solo válida la ausencia de `../`, pero acepta rutas que comienzan con el carácter de directorio raíz `/` (Linux) o `C:\` (Windows), la protección es ineficaz y permite un Absolute Path Bypass (MITRE, 2023).

2.2 Variantes de la vulnerabilidad

El bypass por ruta absoluta es solo una de las múltiples fallas en controles defensivos basados en listas negras (Stuttard & Pinto, 2011):

- **Bypass por Ruta Absoluta:** Omisión de secuencias `../` mediante el envío directo de la ruta canónica desde la raíz (`/etc/passwd`).
- **Bypass por Secuencias Anidadas:** En sistemas que eliminan `../` de manera no recursiva, cargas como `....//` resultan en `../` tras el procesamiento.
- **Bypass por Codificación URL / Doble Codificación:** Manipulación de caracteres hexadecimales (`%2fetc%2fpasswd`) para eludir firmas de Firewalls de Aplicaciones Web (WAF).

2.3 Diferencias entre bases de datos

Al igual que en el caso simple, esta vulnerabilidad interactúa con el sistema de archivos del servidor y no con un sistema gestor de bases de datos (DBMS). No se ejecutan consultas SQL ni se interactúa con tablas de datos; la lectura es directa sobre la estructura de directorios del sistema operativo subyacente.

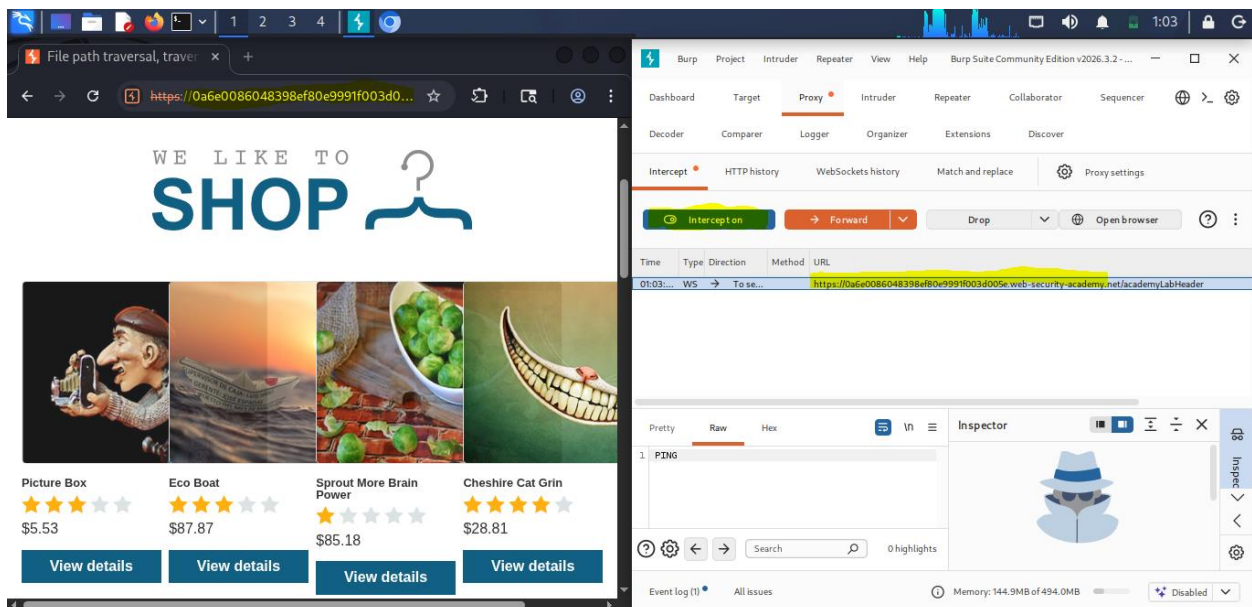
2.4 Impacto en la tríada CIA y OWASP

- **Confidencialidad (Alto Impacto):** Acceso no autorizado a archivos sensibles del sistema operativo (/etc/passwd, /etc/shadow si los permisos lo permitan), variables de entorno con credenciales y código fuente.
- **Integridad (Impacto Variable):** Si el endpoint permite operaciones de escritura o subida de archivos usando rutas absolutas, un atacante podría sobrescribir binarios o archivos de configuración.
- **Disponibilidad (Impacto Variable):** Riesgo de denegación de servicio en caso de alteración de archivos críticos del sistema.
- **OWASP Top 10:** Se clasifica bajo la categoría A01:2021 – Broken Access Control (Control de Acceso Deficiente), ya que la aplicación falla en restringir el acceso a los recursos del sistema de archivos en función de las autorizaciones del cliente. (A01 Broken Access Control - OWASP Top 10:2021, 2021)

3. Procedimiento

Paso 1: Intercepción inicial

Con Burp Suite configurado y el Proxy activo (Proxy > Intercept is on), se accede a la URL del laboratorio.

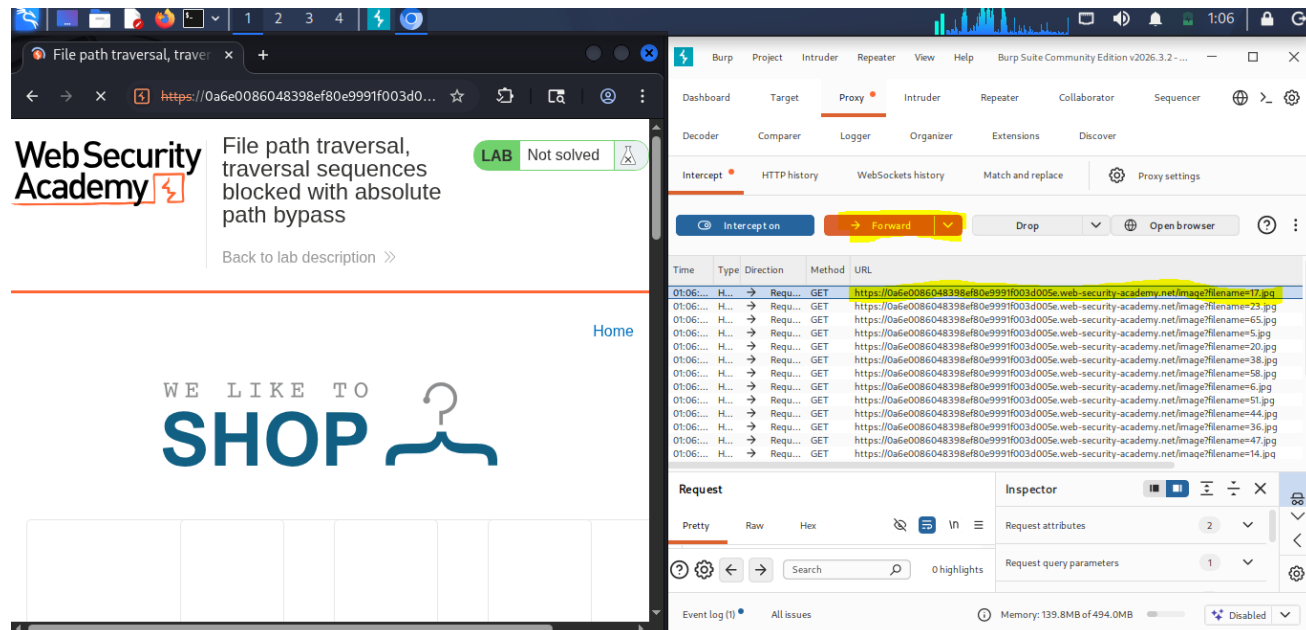


Paso 2: Reenvío de petición con forward

Se presiona el botón **forward** para permitir que la página cargue en el navegador, y luego se navega al detalle de un producto o se inspecciona el catálogo para forzar la carga de las imágenes del sitio `/image?filename=...`

Paso 3: Identificación del endpoint vulnerable

En Burp Suite, se accede a Proxy > HTTP history y se localiza la petición GET `/image?filename=12.jpg HTTP/2`. No importa el número de jpg.



Paso 4: Módulo repeater

Se hace clic derecho sobre la petición de la imagen en la lista del historial y se selecciona **send to repeater**.

Paso 5: Evaluación del control de seguridad

Si se envía la secuencia tradicional `filename=../../../../etc/passwd`, el servidor responde con un error o bloquea la petición debido a un filtro que detecta `../`.

Este comportamiento confirma la presencia de un mecanismo de defensa rudimentario enfocado en secuencias relativas.

The screenshot displays the Burp Suite Repeater interface. At the top, there are tabs for Dashboard, Target, Proxy, Intruder, Repeater (selected), Collaborator, Sequencer, Decoder, Comparer, and Logger. Below the tabs, there is a toolbar with a 'Send' button (highlighted in yellow), a settings gear icon, a 'Cancel' button, and navigation arrows. The main area is divided into 'Request' and 'Response' sections. The 'Request' section shows an HTTP GET request with the following details:

```
1 GET /image?filename=../../../../etc/passwd HTTP/2
2 Host: 0a6e0086048398ef80e9991f003d005e.web-security-academy.net
3 Cookie: session=WjaFJzLgCb9eqdc43bIG030qDzY0XLz7
4 Sec-Ch-Ua-Platform: "Linux"
5 Accept-Language: en-US,en;q=0.9
6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
7 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
8 Sec-Ch-Ua-Mobile: ?0
9 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: no-cors
12 Sec-Fetch-Dest: image
13 Referer: https://0a6e0086048398ef80e9991f003d005e.web-security-academy.net/
14 Accept-Encoding: gzip, deflate, br
15 Priority: u=2, i
16
17
```

The 'Response' section shows an HTTP 400 Bad Request response with the following details:

```
1 HTTP/2 400 Bad Request
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 14
5
6 "No such file"
```

Paso 6: Inyección del payload

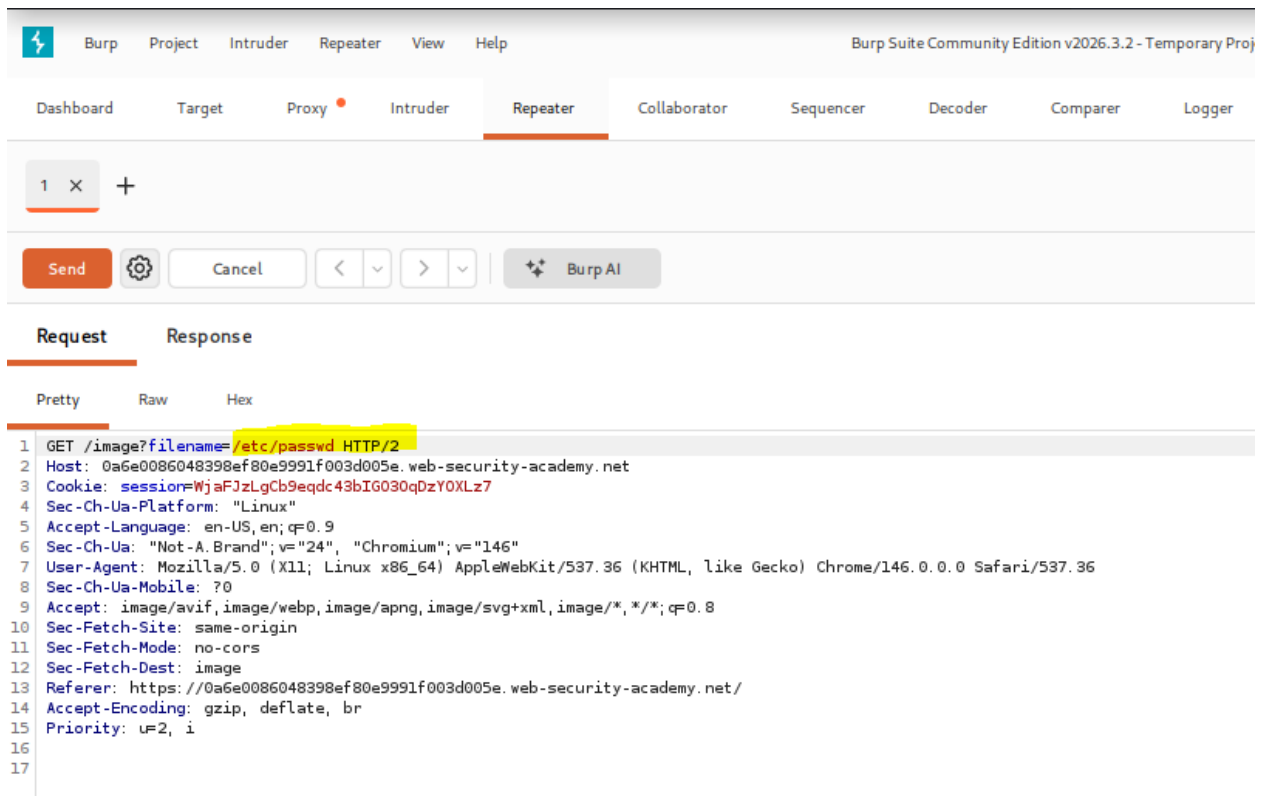
En la pestaña **request** del Repeater, se modifica el valor del parámetro filename por la ruta absoluta directa:

GET /image?filename=/etc/passwd HTTP/2

A continuación, se presiona el botón **send**.

Al colocar /etc/passwd, la aplicación concatena o reemplaza la ruta del directorio base. Como la entrada comienza con /, el sistema operativo lo interpreta como una ruta

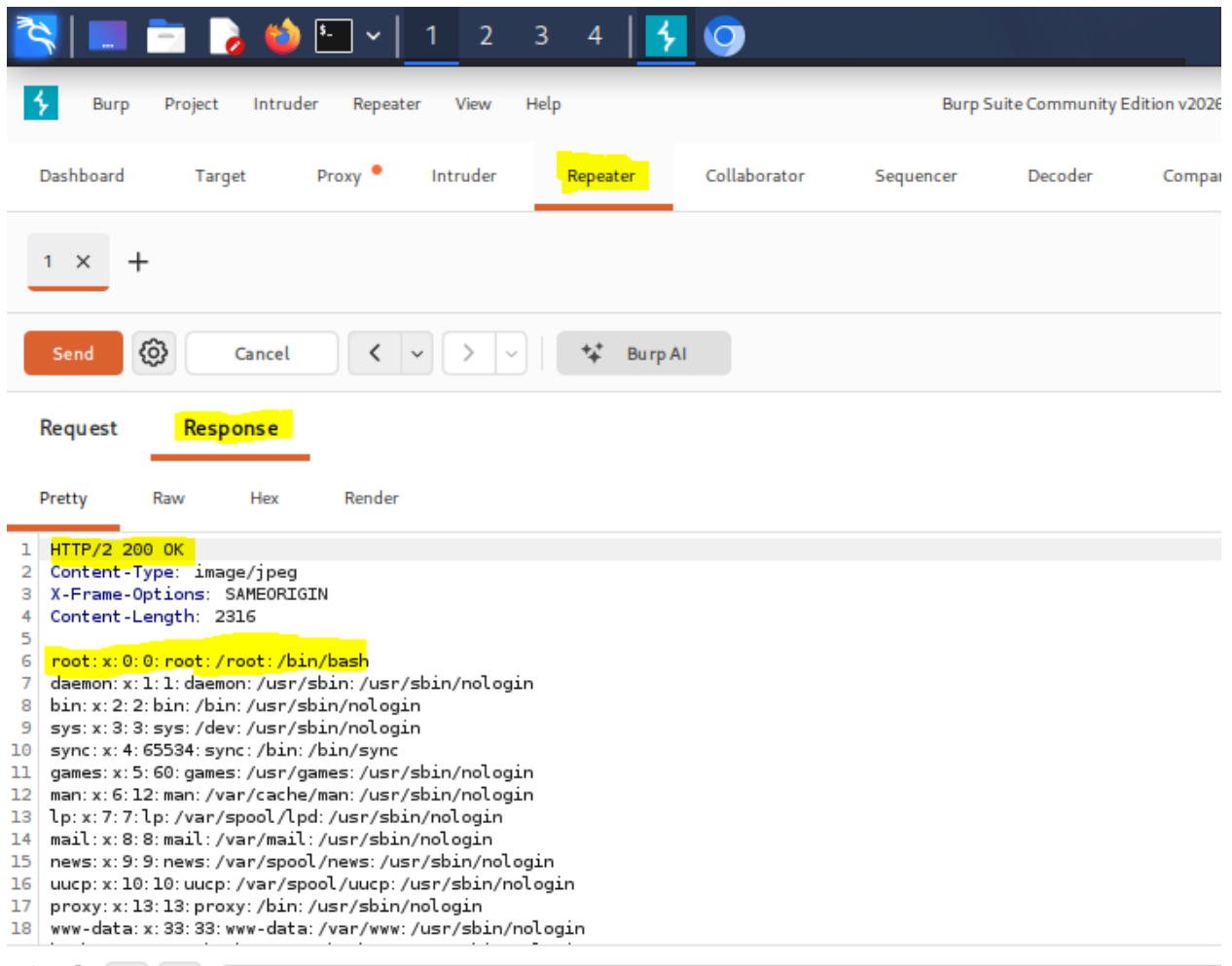
absoluta desde la raíz, ignorando cualquier carpeta de imágenes prefijada y omitiendo el filtro de ../.



Paso 7: Verificación de respuesta

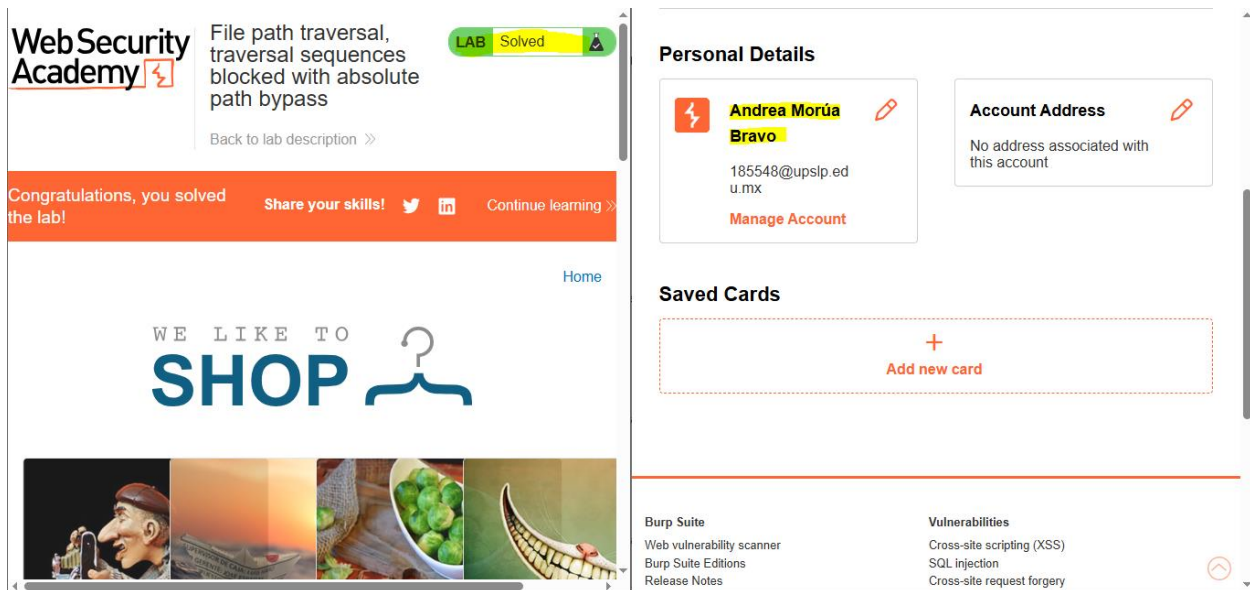
Se cambia a la pestaña **response** dentro del Repeater.

El servidor responde con HTTP/2 200 OK y entrega el contenido del archivo /etc/passwd, mostrando la lista de usuarios del sistema Linux.



Paso 8: Confirmación de resolución

Al recargar la pagina web en el navegador, observamos que el laboratorio fue completado con éxito.



4. Explicación del Payload

Payload utilizado: `/etc/passwd`

El filtro reemplaza `"../"` no encuentra la secuencia y deja la entrada sin cambios. Al procesar la ruta, la función de unión detecta que el segundo argumento `/etc/passwd` es una ruta absoluta, por lo que ignora el prefijo previo `/var/www/images/`. De este modo, el sistema operativo resuelve la ruta directamente hacia `/etc/passwd`, accediendo a la raíz del sistema para leer el archivo de usuarios.

5. Mitigaciones

Para prevenir vulnerabilidades de Path Traversal por bypass de ruta absoluta, se deben adoptar los siguientes patrones de desarrollo seguro:

- En lugar de permitir que alguien pida directamente un archivo escribiendo su nombre o ruta (como `imagen1.jpg` o `/etc/passwd`), el sistema debe usar códigos o números de identificación.
- Si es estrictamente necesario que el usuario envíe un nombre, el servidor debe limpiar la entrada y quedarse solo con el nombre final, ignorando cualquier carpeta o diagonal previa.
- Antes de abrir cualquier archivo, el servidor debe calcular la ubicación exacta donde terminará buscando y confirmar que siga estando dentro de la carpeta permitida.

6. Referencias bibliográficas

MITRE Corporation. (2023). *CWE-22: Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')*. Common Weakness Enumeration. <https://cwe.mitre.org/data/definitions/22.html>

OWASP Foundation. (2021). *A01:2021 – Broken Access Control*. OWASP Top 10:2021. https://owasp.org/Top10/2021/A01_2021-Broken_Access_Control/

PortSwigger. (s.f.). *File path traversal*. Web Security Academy. Recuperado el 22 de septiembre de 2026, de <https://portswigger.net/web-security/file-path-traversal/lab-absolute-path-bypass>